

README - KIT DE INDICADORES GQM+PRAGMATIC EPSS 2026

Guía de Uso del Marco Integrativo

Versión: 1.0

Fecha: Enero 2026

Idioma: Español Profesional

Audiencia: CISOs, Consultores, Auditores, Científicos de Datos

¿QUÉ ES ESTE KIT?

Este kit proporciona un **marco de clase mundial** para diseñar, evaluar e implementar indicadores de ciberseguridad basados en EPSS, con garantías de:

- ✓ **Trazabilidad GQM:** Cada métrica remonta a objetivo estratégico
- ✓ **Practicidad PRAGMATIC:** 9 criterios de viabilidad operacional
- ✓ **Cumplimiento Regulatorio:** Mapeo a NIS2, GDPR, ENS, ISO 27001
- ✓ **Justificación Financiera:** ROI/ROSI cuantificado (430% en ejemplo)

Diferencial: A diferencia de "listas de métricas genéricas", este kit responde:

- ¿CUÁL es la métrica? (definición matemática)
- ¿POR QUÉ? (objetivo estratégico GQM)
- ¿CÓMO se mide? (formula, frecuencia, data sources)
- ¿ES PRÁCTICA? (9 criterios PRAGMATIC: puntuación 7.8/10 promedio)
- ¿VALE LA PENA? (ROI 430%)

CONTENIDO DEL KIT (6 ARCHIVOS)

#	Archivo	Secciones	Público	Tiempo
1	08_marco_gqm_pragmatic.md	Jerarquía Objetivo→Pregunt a→Métrica, 9 criterios PRAGMATIC	Estrategas	45 min
2	09_matriz_pragmatic.md	Evaluación 9 criterios para 7 métricas, tabla comparativa	Analistas	30 min
3	10_mapeo_metricas_normas.md	Trazabilidad métrica↔regulaci ón (NIS2/GDPR/ENS /ISO)	Auditores	20 min
4	11_plantilla_excel_gqm_roi.md	Hojas Excel: Scoring, Trazabilidad, ROI, Dashboard, Decisiones	Técnicos	2h setup
5	12_reporte_ejecutivo_gqm.md	Template presentación a junta: resumen, hallazgos, roadmap	Ejecutivos	15 min
6	README.md	Este archivo - orientación e instrucciones	Todos	10 min

FLUJO DE USO RECOMENDADO

Semana 1: ENTENDIMIENTO

1. Lea 08_marco_gqm_pragmatic.md (45 min)
2. Entienda 3 niveles GQM: Objetivo → Pregunta → Métrica
3.
Entienda 9 criterios PRAGMATIC (Predictivo, Relevante, Accionable...)
4.
Revise 09_matriz_pragmatic.md (20 min)
5. Vea ejemplos reales de métricas evaluadas
6.
Compare scores: A1 (8.7/10) vs B1 (7.5/10)
7.
Consulte 10_mapeo_metricas_normas.md (15 min)
8. Valide que métricas cumplen su regulación aplicable
9. Identifique requisitos críticos (NIS2 Art 21/E, GDPR Art 32)

Entienda 9 criterios PRAGMATIC (Predictivo, Relevante, Accionable...)

Revise 09_matriz_pragmatic.md (20 min)

Compare scores: A1 (8.7/10) vs B1 (7.5/10)

Consulte 10_mapeo_metricas_normas.md (15 min)

Semana 2: IMPLEMENTACIÓN

10. Configure 11_plantilla_excel_gqm_roi.md (2-3 horas)
11. Copie estructura en Google Sheets o Excel
12. Hoja 1: Scoring (6 métricas principales)
13. Hoja 2: Trazabilidad GQM (objetivos)
14. Hoja 3: ROI/ROSI (business case)
15. Hoja 4: Dashboard (KPIs seguimiento)
16.
 Hoja 5: Decision Matrix (acciones por score)
17.
 Complete Scoring Manual (2-3 horas)
18. Recopile datos actuales de cada métrica
19. Ejemplo: A1 Cobertura EPSS = 72% (vs target 80%)
20. Calcule PRAGMATIC scores (usar matriz 09 como referencia)

Hoja 5: Decision Matrix (acciones por score)

Complete Scoring Manual (2-3 horas)

Semana 3: COMUNICACIÓN

21. Elabore Reporte Ejecutivo (4-5 horas)
22. Use template 12_reporte_ejecutivo_gqm.md
23. Complete secciones: Resumen, GQM, PRAGMATIC, Recomendaciones
24. Incluya tabla resumen + gráficos (radar de scores)
25.
 Prepare business case: €145K inversión → 430% ROSI
26.
 Presente a Junta Directiva (1 hora)
27. Slides: Resumen ejecutivo + 3 mensajes clave
28. Recomendación: APROBAR inversión
29. Timeline: Q1-Q2 2026

Prepare business case: €145K inversión → 430% ROSI

Presente a Junta Directiva (1 hora)

CASOS DE USO ESPECÍFICOS

Caso A: "Soy CISO y necesito diagnóstico basal en 2 semanas"

Flujo acelerado:

1. Lee 08_marco_gqm_pragmatic.md (45 min)
2. Completa solo Métrica A1-A3, D1 (las más críticas)
3. Calcula PRAGMATIC scores usando 09_matriz_pragmatic.md
4. Genera reporte 1-página (Resumen Ejecutivo only)
5. Presenta a C-suite: "Métricas de calidad 7.8/10, necesitamos €145K para mejorar"

Output: IGM basal + 3 métricas críticas = validación estratégica

Caso B: "Soy Auditor validando cumplimiento NIS2/GDPR"

Flujo auditoria:

1. Revisa 10_mapeo_metricas_normas.md completamente
2. Mapea cada requisito NIS2 Art 21(E) → Métrica → Evidencia
3. Verifica que scores PRAGMATIC ≥ 7.0 (practicidad auditada)
4. Valida trazabilidad GQM (Objetivo → Pregunta → Métrica)
5. Genera reporte de cumplimiento: "100% de requisitos NIS2 cubiertos"

Output: Matriz de auditoría + evidencias completas

Caso C: "Soy Data Science y debo mejorar predicción EPSS"

Flujo técnico:

1. Lee 08_marco_gqm_pragmatic.md (Criterio 1: Predictivo)
2. Revisa 09_matriz_pragmatic.md Métrica A3 (Efficiency EPSS = 7.9/10)
3. Analiza: "¿Por qué efficiency no es 9/10? ¿Qué falta?"
4. Plan de mejora: Validación contra KEV histórico, ML retraining
5. Re-escanea métrica: A3 = 9/10 (predictividad mejorada)

Output: Plan de mejora técnica con justificación

Caso D: "Soy CFO y tengo €300K, ¿dónde invertir?"

Flujo financiero:

1. Lee sección ROI de 11_plantilla_excel_gqm_roi.md
2. Identifica que €145K en mejoras → 430% ROSI (€495K retorno)
3. Calcula payback: 2.3 meses (vs presupuesto típico 12-18 meses)
4. Aprueba inversión: "Best value for money"
5. Asigna presupuesto: €50K SIEM + €50K MTTR tools + €45K resto

Output: Business case aprobado + roadmap de gasto

INDICADORES CLAVE MEDIDOS

Métrica	GQM Objetivo	PRAGMATIC Score	Regulación	Ejemplo Actual
A1: Cobertura EPSS	Asegurar $\geq 80\%$ CVEs tienen predicción	8.7/10	NIS2 21(E)	72%
A2: MTTR Críticas	Remediación < 7 días (EPSS ≥ 0.50)	7.6/10	NIS2/GDPR	14 días
A3: Efficiency EPSS	Validar que EPSS discrimina bien	7.9/10	NIS2 21(E)	52%
B1: MTDD	Detección $< 24h$ de incidentes	7.5/10	GDPR 33	26h
C1: MTTE	Notificación regulador $< 24h$	7.7/10	NIS2 19(1)	20h
D1: Phishing Click	Capacitación efectiva $< 15\%$ click	8.1/10	NIS2 21(D)	22%
E1: Documentación	95%+ decisiones auditables	7.8/10	GDPR 32	85%

INTERPRETACIÓN DE RESULTADOS

PRAGMATIC Score

9.0-10.0: ★ EXCELENTE

└ Métrica lista para producción sin cambios

8.0-8.9: ★★ MUY BUENA

└ Implementar con documentación clara

7.0-7.9: ★★★ BUENA

└ Implementar pero mejorar (precisión, automatización)

6.0-6.9: ★★★★ ACEPTABLE

└ Reconsiderar o mejorar significativamente

< 6.0 : ★★★★★ DEFICIENTE

└ NO RECOMENDAR implementación hasta mejora

IGM Global

IGM = PROMEDIO(PRAGMATIC scores todas métricas)

8.5-10.0: EXCELENTE (programa maduro, auditable)

7.5-8.4: BUENA (programa operativo, con mejoras posibles)

6.5-7.4: ACEPTABLE (programa básico, requiere inversión)

< 6.5 : DÉBIL (riesgo alto de error en decisiones)

PREGUNTAS FRECUENTES (FAQ)

P: ¿Puedo usar este kit si NO estoy en España?

R: Sí. Reemplaze "NIS2/GDPR/ENS" con regulación local (CCPA, HIPAA, etc).
Framework GQM+PRAGMATIC es agnóstico.

P: ¿Cuál es la diferencia vs "top 30 metrics lists"?

R: Trazabilidad. Listas genéricas dicen "mida MTTR".
Este kit dice: "MTTR responde pregunta Q1.1, que sirve objetivo OB-1,
que mapea a NIS2 Art 21(E), con practicidad PRAGMATIC 7.6/10,
ROI 430%, ejemplo actual 14 días vs target <7 días."

P: ¿Necesito Excel específicamente?

R: No. Google Sheets, Tableau, Power BI, cualquier tool funciona.
Importa la estructura, no el software.

P: ¿Cada cuánto recalcular IGM?

R: Recomendado: Anualmente (cambios significativos).
Trimestralmente: Para tracking de KPIs.
Mensualmente: Para métricas operacionales como MTTR.

P: ¿Puedo ignorar métricas con PRAGMATIC <7.0?

R: Sí, si costo > beneficio. Pero documente por qué se omite.
Recomendación: Implementar todo ≥ 7.0 .

ROADMAP DEL KIT (Futuro)

Versión 2.0 (Q3 2026):

- Integración automática con API EPSS (scores en vivo)
- Dashboard Tableau/Power BI interactivo
- Predicción de MTTR usando ML (modelo entrenado)
- Configuración pre-cargada por industria (Banca, Salud, Fintech)
- Benchmarking anónimo vs pares

SOPORTE Y CONTACTO

Problemas técnicos con Excel:

- Revise sección "Fórmulas Recomendadas" en 11_plantilla_excel_gqm_roi.md

Dudas sobre GQM:

- Consulte 08_marco_gqm_pragmatic.md Parte 1 (Estructura Jerárquica)

Validación regulatoria:

- Use 10_mapeo_metricas_normas.md

Presentación ejecutiva:

- Template completo en 12_reporte_ejecutivo_gqm.md

SIGUIENTE PASO: COMIENCE AQUÍ

Si es EJECUTIVO (5 min):

- Lea "Resumen Ejecutivo" de este README + tabla "Indicadores Clave"

Si es CISO (1 hora):

- 1) Lee 08_marco_gqm_pragmatic.md
- 2) Revisa 09_matriz_pragmatic.md
- 3) Planifica semana de implementación

Si es AUDITOR (2 horas):

- 1) Completa 10_mapeo_metricas_normas.md
- 2) Mapea a regulación aplicable
- 3) Valida trazabilidad GQM

Si es TÉCNICO/DATA SCIENCE (3-4 horas):

- 1) Configura Excel de 11_plantilla_excel_gqm_roi.md
- 2) Calcula PRAGMATIC scores
- 3) Carga datos actuales de organización

LICENCIA Y ATRIBUCIÓN

Kit desarrollado por: Consorcio de Científicos de Datos y Estrategas de Ciberseguridad

Fecha: Enero 2026

Versión: 1.0

Clasificación: Información Operacional (libre distribución)

Cita recomendada:

"Framework GQM+PRAGMATIC para Indicadores EPSS, Consorcio de Científicos de Datos, Enero 2026"

VERSIÓN Y CONTROL DE CAMBIOS

Versión	Fecha	Cambios
1.0	24 Ene 2026	Release inicial
1.1	Próximo	Integración API EPSS automática
2.0	Q3 2026	Dashboard interactivo + ML predictions

¡Bienvenido al Framework GQM+PRAGMATIC!

Diseñado para profesionales que demandan trazabilidad, practicidad y valor.



Enero 2026